

Grado en Ingeniería informática
2025-2026

Trabajo Fin de Grado

Exploiting Retrieval Latency Side-Channels in
RAG Systems.

Sergio Verde Llorente

Tutor/es

José María de Fuentes

Lugar y fecha de presentación prevista



[Incluir en el caso del interés de su publicación en el archivo abierto]

Esta obra se encuentra sujeta a la licencia Creative Commons **Reconocimiento – No Comercial – Sin Obra Derivada**

Descripción detallada del tema planteado

El proyecto se centra en investigar un posible fallo de seguridad en los sistemas RAG, que son los que usan las empresas para que la IA lea sus propios documentos. Mi enfoque es diferente a lo habitual ya que quiero fijarme en la base de datos donde se guarda la información. El escenario real que planteo es el de una empresa con un chat interno donde se mezcla información pública con archivos confidenciales que no todos deberían saber que existen.

Para poner esto a prueba, voy a realizar un experimento lanzando "preguntas trampa" sobre temas sensibles (como por ejemplo "listado de despidos") y voy a medir con mucha precisión cuánto tarda el sistema en procesar la búsqueda. Mi teoría es que los algoritmos que usan estas bases de datos no tardan siempre lo mismo: creo que cuando encuentran documentos sobre un tema, les cuesta un poco más de trabajo procesarlos que cuando buscan en una zona vacía.

El objetivo final es comprobar si esas pequeñas diferencias de tiempo son reales y medibles. Quiero ver si un atacante podría llegar a deducir que un documento secreto existe simplemente cronometrando la espera, incluso si al final el chatbot responde con un "no tengo permisos para ver esto". Básicamente, busco ver si la velocidad de la búsqueda delata la existencia del archivo.

Tabla de comparación con trabajos científicos.

No he podido encontrar trabajos del tema exacto que quiero tratar, pero he encontrado muchos trabajos que utilizan cosas similares. Por ejemplo, hay varios que utilizan el tiempo a primer token, que es lo que yo quiero medir, pero lo utilizan para medir tiempo de acierto a cache o para clasificar un tema. Otro también hace búsqueda de datos en la Retrieval Database pero lo hace mirando la confianza de respuesta de la IA. Además, no he encontrado trabajos de las revistas que nos ofreciste, pero he seleccionado los de arXiv que me parecían más potentes o que tenían sentido que fueran buenos por las personas que los hacen. La explicación de porque los he seleccionado se encuentra entre paréntesis en la columna de revista. He añadido una descripción de cada paper más detallada después de la tabla ya que no tenía hueco en la misma.

Año	Título	Revista	Componente Atacado	Características	Señal Medida	Link
2025	Is My Data in Your Retrieval Database? Membership Inference Attacks Against Retrieval Augmented Generation	arXiv (Harvard University)	Salida del LLM (Probabilidad)	Usa estadísticas de texto (confianza/entropía) para inferir datos.	log-probabilities seguridad de la IA al responder.	https://arxiv.org/abs/2405.20446

2024	InputSnatch: Stealing Input in LLM Services	arXiv (Tema similar, ya que busca si algo esta guardado, pero con la cache y con prompts en vez de con archivos)	Memoria Caché	Envía sondas para detectar si una respuesta es "instantánea", indicando que otro usuario ya hizo esa consulta antes.	Tiempo de Acierto en Caché	https://arxiv.org/abs/2411.18191
2025	BudgetLeak: Membership Inference on RAG	arXiv (Usa RAG solo que con otro tipo de ataque pero centrándose en el conocimiento)	LLM (Fase de Generación)	Manipula el presupuesto de tokens para ver si el LLM cambia su comportamiento al acceder a un dato privado.	Tokens usados	https://arxiv.org/abs/2511.12043
2025	WhisperLeak: Side-channel attack on LLM	arXiv (Microsoft) (Las empresas han hecho cambios gracias a este trabajo)	Tráfico de Red	Analiza patrones de tiempo y tamaño de paquetes en respuestas token a token cifradas para clasificar el tema.	Patrón de Tráfico	https://arxiv.org/abs/2511.03675
2025	Mi proyecto	N/A	Base de Datos Vectorial	Explota la carga computacional variable de los algoritmos de búsqueda dependiendo de la densidad de los datos.	Tiempo de Búsqueda	N/A

Ya que en la tabla no cabe toda la información que me gustaría sobre los trabajos que he investigado para hacer este estado del arte, voy a hacer una explicación de cada trabajo que añada los datos faltantes de cada uno.

1- Is My Data in Your Retrieval Database? Membership Inference Attacks Against

Retrieval Augmented Generation: Este paper es muy interesante para el estudio de este estado del arte ya que trabaja con bases de datos RAG. En este sentido este trabajo es muy cercano a mi tema, ya que realiza un estudio de si un archivo está o no presente en una base de datos. La principal diferencia es que en este paper se estudia esto usando las respuestas del modelo y los log-probabilities, que es la probabilidad que tiene el LLM de predecir un token u otro. En este caso se prueban dos entornos.

- 1- Black box: En este entorno el usuario solo ve el chat y simplemente se centrará en la respuesta del modelo para saber si un archivo está presente o no en el contexto que este obtiene por detrás. El problema de este entorno fue que a veces la IA

alucinaba dando la respuesta, entre sí y no, menos probable. Pero igualmente obtuvieron valores de AUC-ROC y de TPR@FPR altos (0.6 – 1) dependiendo del modelo y datos utilizados (0.8 media de AUC-ROC).

- 2- **Gray box:** Lo que ellos llaman gray box es un modelo al cual se tiene acceso a metadatos como los log-probabilities que es el dato que han estudiado. En este caso los valores de medición mejoraron considerablemente (0.9 media de AUC-ROC).

También cabe mencionar que en este paper se estudian dos datasets (HealthCareMagic y Enron) y tres modelos (flan, llama, mistral). El paper concluye que los ataques de privacidad de este estilo se pueden realizar sin conocimiento del RAG que se este utilizando y que es necesario más medidas de seguridad para solucionar este problema.

- 2- **InputSnatch: Stealing Input in LLM Services:** Lo interesante de este trabajo es que usa la medición del tiempo de respuesta como medio para realizar su ataque. En este caso el ataque se basa en un ataque a las caches de los sistemas de IA que tienen prompt caching o prefix caching. Lo que se quiere saber en este paper es si con el tiempo de respuesta se puede inferir de que temas o prompts exactos ha hablado otro usuario. La idea es que cuando un usuario lanza un prompt sobre un tema a la IA y esta tiene una cache compartida. Ese tema/prompt se guarda en la cache y cuando otro usuario pregunta por lo mismo el LLM tarda menos de lo que debería en responder. En este caso se usa un dataset con conversaciones de médicos con pacientes con 110K datos llamado Chatdoctor. Además, utilizan varios modelos de llama y GPT. En cuanto a los resultados se obtiene mejor resultados en la obtención de los temas que de los prompt exactos.
- 3- **BudgetLeak: Membership Inference on RAG:** Este paper estudia un ataque basado en el número máximo de tokens que tiene un LLM. El ataque se basa en inferir si un documento existe o no en un RAG basándose en la completitud de la respuesta de la IA. Esto se realiza con dos enfoques uno en el que el atacante tiene “Partial Knowledge”, conoce el funcionamiento del sistema RAG atacado, y otro en el que tiene “Zero Knowledge”. El primer enfoque se realiza entrenando un modelo para saber interpretar los patrones en los que el LLM si tiene conocimiento del documento. El segundo se realiza usando un solo método de clustering que clasificará las respuestas. Los modelos utilizados en ambos son LLaMa, Mistral y ChatGLM. Además, en el paper se compara este ataque con otros tipos y este supera por mucho a los demás. Como medidas de precisión utilizadas se mide: el $\text{TPR at 0.1\%FPR}$ (1.3-18.5), el Accuracy (0.8-0.91) y el AUC (0.73-0.97). Además, para mayor precisión en este paper se llegan a utilizar hasta 4 datasets distintos: HealthCareMagic-100k, Natural Questions, MS-MARCO y AGNews. Obviamente los resultados obtenidos son muy buenos y además se mide la robustez del ataque y resulta ser muy buena.
- 4- **WhisperLeak: Side-channel attack on LLM:** Este paper me ha parecido muy bueno mencionarlo ya que usa el tiempo de respuesta como ataque. En este caso lo que se estudia es si escuchando el trafico de red que tiene la víctima con un LLM se puede

inferir el tema del que está hablando. Para esto se entrena un modelo clasificador con muchos tamaños de paquetes y tiempos de respuesta sobre un tema específico, en este caso el lavado de dinero. Como dataset se utilizó Quora Questions Pair que tenía 11k preguntas sobre distintos temas. Además, se realizaron 100 preguntas modelo sobre lavado de dinero para entrenar al clasificador. Como modelos se usaron muchísimos modelos comerciales desde distintos modelos de Gemini a muchos otros de GPT pasando por algunos de Grok y deepseek. También se hizo un estudio del ataque usando por separado el tamaño de los paquetes y el tiempo y también estudiándolos juntos. Se obtuvieron valores de precisión y recall muy altos. Por otro lado, se estudiaron distintas maneras de mitigar este ataque como por ejemplo aplicar ofuscación. Por último, dado que los resultados fueron alarmantes y el peligro encontrado era real, antes de publicar el paper, contactaron con las distintas empresas propietarias de los modelos y les ayudaron a arreglarlo.

Creo que en comparación a los papers que he encontrado mi tema tiene mucha potencia por dos razones:

- Es un tema muy novedoso, no solo porque todos los papers que tratan sobre temas similares son muy recientes (2024-2025) si no porque no he encontrado ningún paper que mida la aparición de un documento en una base de datos por el tiempo de respuesta de la IA. Creo que la mayoría de las veces el tiempo de respuesta se utiliza para otras cosas como la clasificación de un tema o la aparición de este en una memoria cache, pero creo que no ha sido probado si es posible observar que un archivo se encuentre en la base de datos por el tiempo de respuesta que tenga la IA.
- Creo que mi trabajo sería una combinación de los papers anteriormente mencionados ya que trata de saber si un documento está en un RAG como el número 1 pero con el tipo de ataque que se realiza en el número 2/4. Creo que sería de gran interés poder encontrar un fallo de privacidad en la combinación del estudio de tiempos de respuesta y el uso de un RAG empresarial real. Creo que si la hipótesis acaba siendo real podría tener un impacto ya que la idea es usar las herramientas usadas en los RAG empresariales reales.